UNIT 1 · TOPIC 1.5

Leveraging AI in Cyber Defense

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following BEST describes the primary function of an AI-powered Intrusion Prevention System (IPS)?

○ A. A firewall that blocks traffic based solely on a static list of known bad IP addresses

● **B. A security control that uses machine learning to detect and block malicious network traffic in real time**

○ C. A tool that encrypts data at rest to protect its confidentiality from unauthorized access

○ D. A system that logs all user login attempts without taking any automated action

Correct answer: B

Why: An AI-powered IPS uses machine learning models trained on traffic patterns to identify and automatically block threats in real time, extending well beyond static rule sets. Encryption (C) protects data confidentiality but does not detect or block network threats. Logging alone (D) is a detective function with no prevention capability. Static IP blacklists (A) describe legacy firewalls, not AI-assisted systems.

*Why the others are wrong: **A**, Confuses an AI-powered IPS with a legacy firewall operating on static allow/deny rules; static blacklists cannot detect novel or unknown threats. **C**, Encryption is a data-protection control targeting confidentiality, not a network traffic monitoring or prevention mechanism. **D**, A logging system is a detective control; it records events after they occur but does not prevent or block malicious activity.*

2. In the scenario, the developer uses an AI tool to review application code and flag security vulnerabilities before the web application is launched. This is an example of which type of security control?

● **A. Preventive, it identifies and addresses vulnerabilities before they can be exploited**

○ B. Corrective, it responds to and remedies an incident after it has occurred

○ C. Detective, it identifies attacks as they happen during normal operation

○ D. Compensating, it substitutes for another control that cannot be implemented

Correct answer: A

Why: Identifying vulnerabilities before the application is deployed prevents a threat from ever being exploited in production, the defining characteristic of a preventive control. Detective controls (C) identify attacks after they occur. Corrective controls (B) remediate after an incident. Compensating controls (D) substitute for unavailable primary controls.

*Why the others are wrong: **B**, Corrective controls act after an incident has occurred, such as restoring from backup after a ransomware attack, not before deployment. **C**, A detective control fires during or after an event (e.g., an IDS alert during a live SQL injection attempt), not during pre-deployment code review. **D**, Compensating controls are workarounds for controls that cannot be implemented; pre-deployment code review is a primary control, not a substitute.*

3. Which of the following is MOST accurately described as an AI-assisted security control for protecting application data from injection attacks?

○ A. A password policy requiring all users to create passwords of at least eight characters

○ B. A physical lock on the server room door to prevent unauthorized hardware access

● **C. An AI tool that validates and sanitizes user input before passing it to a database query**

○ D. A scheduled weekly backup of the database to an off-site location

Correct answer: C

Why: Input validation and sanitization is an application-layer control that directly targets injection vulnerabilities, the AI tool in the scenario applies exactly this pattern. Password policies (A) address authentication, not application injection.

Physical locks (B) protect hardware access. Backups (D) are a recovery/resilience control, not a proactive AI-assisted defense against injection attacks.

*Why the others are wrong: **A**, A password policy is a managerial/access control; it does not address the database query layer where injection attacks occur. **B**, Physical security prevents unauthorized physical access to hardware but does not protect application data from network-based injection attacks. **D**, Backups restore data after an incident; they do not prevent an injection attack from occurring or succeeding in the first place.*

4. A software team is building an e-commerce site that connects to a product inventory database. An AI code-review tool flags five input fields where user-supplied data is passed directly into SQL queries without any validation. How does implementing the tool's recommended input validation MOST directly mitigate the identified risk?

- ○ A. It encrypts the database contents so adversaries cannot read the data even if they gain access
- ○ B. It limits the number of failed login attempts before automatically locking out a user account
- ○ C. It monitors all inbound network traffic to the server and blocks packets matching known attack signatures
- **● D. It prevents adversaries from submitting crafted input that could manipulate the structure of database queries**

Correct answer: D

Why: SQL injection exploits unsanitized input fields to alter query logic. Input validation ensures only expected, properly-typed data is passed to the database, directly blocking the attack vector the AI tool identified. Encryption (A), network monitoring (C), and account lockout (B) each address different, orthogonal threat vectors.

*Why the others are wrong: **A**, Encryption protects data at rest and in transit but does not prevent a SQL injection payload from executing a malicious query against the database engine. **B**, Account lockout addresses brute-force credential attacks, not injection vulnerabilities where no authentication bypass is required. **C**, Network monitoring is a detective control operating at the network layer; it does not address injection vulnerabilities embedded in application-layer code.*

5. A company uses an AI-powered Security Information and Event Management (SIEM) system that correlates logs from ten systems. It flags a pattern where a privileged account is accessing payroll files at 2:00 AM every night, though the account owner has never worked night shifts. Which security goal does the SIEM alert MOST directly support?

- ○ A. Ensuring the availability of payroll files for authorized users during business hours
- ○ B. Encrypting payroll data to protect its confidentiality from unauthorized disclosure
- **● C. Identifying potential insider threat activity before data is exfiltrated or damaged**
- ○ D. Preventing all after-hours access to the payroll system through a blanket access block

Correct answer: C

Why: The SIEM is correlating behavioral anomalies, off-hours access by a privileged account, to flag a potential insider threat before damage occurs. This is a detection-focused security goal. Availability (A) concerns uptime for legitimate users. Encryption (B) is a data-protection goal. Blocking all after-hours access (D) describes a different control policy, not what the SIEM is doing.

*Why the others are wrong: **A**, Availability refers to ensuring systems are accessible to authorized users when needed; the SIEM alert concerns suspicious access patterns, not a service outage. **B**, Encryption addresses confidentiality at rest or in transit; the SIEM alert is about behavioral anomaly detection, not data encryption status. **D**, A blanket after-hours block would be an access control policy change; the SIEM is detecting anomalies within existing access rules, not enforcing new ones.*

6. An organization wants to reduce the time between when a new vulnerability is discovered in its web server software and when a patch is deployed. Which AI-assisted security control BEST addresses this specific goal?

- ○ A. A physical security camera installed near the server rack to deter unauthorized hardware access
- ○ B. A managerial policy requiring IT staff to review vendor patch notes on a quarterly schedule
- **● C. An AI-powered vulnerability scanner that continuously monitors public CVE databases and automatically alerts the team when relevant new vulnerabilities are published**

○ D. A password manager enforcing multi-factor authentication for all administrative accounts

Correct answer: C

Why: Continuous AI-powered CVE monitoring directly reduces patch latency by eliminating the gap between publication and awareness. Quarterly patch reviews (B) introduce exactly the lag the organization wants to eliminate. Physical cameras (A) and MFA (D) are valid security controls that address entirely different threat vectors, hardware access and authentication respectively.

*Why the others are wrong: **A**, Physical cameras deter unauthorized physical access to hardware; they have no role in software vulnerability management or patch deployment timelines. **B**, Quarterly review cycles create a predictable vulnerability window of up to three months; this is the opposite of the continuous AI-assisted monitoring the question asks about. **D**, MFA strengthens account authentication against credential-based attacks but does not address the speed of vulnerability discovery or patch deployment.*

7. A cybersecurity team debates whether to replace their entire security stack with a single AI-powered platform promising unified threat prevention, detection, and response. A senior analyst argues against it, citing defense-in-depth principles. Which reasoning BEST supports the analyst's position?

○ A. AI security platforms are generally too expensive for most organizations to deploy as a complete solution

○ B. Current AI tools cannot aggregate and correlate logs from more than one data source at a time

○ C. Human security analysts are always more accurate than AI-powered tools at detecting advanced persistent threats

● D. A single unified platform creates a monoculture, if the AI model is evaded or fails, all three security functions fail simultaneously

Correct answer: D

Why: Defense-in-depth requires heterogeneous, layered controls so that the failure of one layer does not compromise all others. A single-vendor AI platform creates a single point of failure, one evasion technique defeats prevention, detection, and response simultaneously. Cost (A) is practical but not the security principle. C is empirically false; AI tools outperform humans on high-volume log analysis. D is factually incorrect, SIEM products are defined by multi-source log aggregation.

*Why the others are wrong: **A**, Cost is a legitimate operational consideration but is not the defense-in-depth security principle the analyst is invoking; cost alone does not address the architectural risk. **B**, Multi-source log aggregation is a core, defining feature of SIEM tools; this claim is factually incorrect and would not constitute a credible security argument. **C**, This is a sweeping empirical overclaim; AI tools frequently outperform human analysts in volume-based detection tasks, making this an unreliable basis for the argument.*

8. In the scenario, an AI code-review tool recommends code changes to address injection vulnerabilities. The development team implements all recommended changes without review and pushes them directly to production. Which risk does this approach MOST significantly introduce?

○ A. The AI tool may have identified fewer vulnerabilities than a full manual penetration test would have found

○ B. Customers will be unable to place orders until the AI tool re-reviews the updated code before deployment

○ C. Input validation routines will significantly degrade database query performance under high traffic loads

● D. Unreviewed AI-generated code changes could introduce new logical errors or unintended behaviors into the production system

Correct answer: D

Why: AI code-fix recommendations can be contextually incorrect, overly broad, or introduce subtle logic errors. The scenario explicitly states the team should review changes before implementation for this reason. Unreviewed automated changes can create new defects in production. A describes a detection-scope limitation, not an implementation risk. C and D are speculative and unsupported by the scenario or standard practice.

*Why the others are wrong: **A**, Insufficient detection coverage is a separate limitation of the AI tool's scanning scope; it describes a risk of what the tool might miss, not a risk introduced by unreviewed implementation of what it did find. **B**, There is no standard practice or evidence in the scenario requiring the AI tool to re-review code before customer access is granted; this option is not grounded in real-world deployment processes. **C**, Performance impact from input validation is a valid engineering consideration but is secondary to the security risk of introducing new defects; it is also speculative without profiling evidence.*

9. An organization deploys three layered AI-powered controls: (1) an AI IDS monitoring inbound network traffic, (2) an AI code-review tool for all application deployments, and (3) an AI SIEM correlating logs across all systems. A new ransomware strain evades the IDS by using encrypted command-and-control channels, but the SIEM detects anomalous outbound traffic volume from an infected endpoint. What does this outcome BEST demonstrate about the organization's AI security architecture?

- ○ A. The AI IDS is misconfigured and should be decommissioned and replaced with a human security analyst
- ○ B. The SIEM is the only AI tool worth deploying since it detected the threat that the IDS missed
- **● C. Layered AI controls can compensate for individual tool failures when each tool operates on different evidence sources and detection methods**
- ○ D. Encrypted command-and-control traffic is undetectable by any security control and should be accepted as an unavoidable residual risk

Correct answer: C

Why: The outcome is a direct demonstration of defense-in-depth: the IDS failed against encrypted C2 (traffic-pattern evasion), but the SIEM succeeded using behavioral volume anomalies, a different evidence source. Neither tool alone would have caught this threat at every stage. A is unsupported; evasion in one threat scenario does not indicate misconfiguration. C overgeneralizes from a single incident. D is empirically false, behavioral controls detect encrypted C2 by volume and timing patterns, as this scenario demonstrates.

*Why the others are wrong: **A**, An IDS being evaded by a specific encrypted-channel technique reflects a known limitation of signature/traffic inspection, not misconfiguration; replacing it with a human analyst would eliminate automated detection of the many threats the IDS does catch. **B**, Overgeneralizing from one detection outcome to permanently ranking tools ignores that the IDS provides coverage against many threats that behavioral volume analysis would miss entirely. **D**, The scenario itself disproves this claim, the SIEM detected the encrypted C2 activity through behavioral volume anomalies, demonstrating that encrypted C2 is not universally undetectable.*

10. Which of the following BEST describes how an AI-powered Intrusion Detection System (IDS) monitors network traffic to identify threats?

- ○ A. It scans the database server for unauthorized changes to stored records at scheduled intervals
- ○ B. It encrypts all outbound network packets to prevent an adversary from reading transmitted data
- ○ C. It automatically locks out user accounts after a pre-configured number of failed authentication attempts
- **● D. It learns a baseline of normal network behavior through training and flags traffic that deviates significantly from that baseline**

Correct answer: D

Why: AI-powered IDS uses machine learning to model normal baseline behavior and flags anomalous deviations, the defining mechanism of behavioral anomaly detection. Database scanning (A) is a separate database activity monitoring function. Account lockout (C) is an access control mechanism unrelated to network monitoring. Encryption (B) is a data-protection control, not a detection method.

*Why the others are wrong: **A**, Database activity monitoring is a distinct tool category; a network IDS operates on traffic flows, not stored database records. **B**, Encryption prevents interception of data in transit but is a protection control, not a method for detecting threats or monitoring network behavior. **C**, Account lockout is an access control response triggered by authentication failures; it is not a network monitoring or anomaly detection mechanism.*

11. In the scenario, the AI code-review tool produces a report flagging specific input fields as potential injection vulnerabilities. What type of evidence does this report represent in the context of a pre-deployment security review?

- **● A. Application-layer findings identifying specific locations in source code where user input is handled unsafely**
- ○ B. A physical access log recording which personnel entered the server room during development
- ○ C. A network packet capture recording malicious traffic targeting the application in real time
- ○ D. A browser history file showing which websites the development team accessed during the project

Correct answer: A

Why: The AI tool's output is static application-layer evidence, it identifies specific code locations where input handling creates injection risk. This is the correct characterization of static analysis tool output used in a pre-deployment review. Packet captures (C) are network-layer evidence from live traffic. Physical access logs (B) are physical-layer evidence. Browser history (D) is user activity evidence with no relevance to code vulnerability analysis.

*Why the others are wrong: **B**, Physical access logs track hardware-layer events; they have no relationship to the application source code being analyzed by the AI tool. **C**, Packet captures record live network traffic; the scenario describes static code review before the application is deployed, when there is no live attack traffic to capture. **D**, Browser history records user browsing activity; it does not describe the structured, code-specific output of a security analysis tool.*

12. Which monitoring method would MOST likely detect a previously unknown (zero-day) malware variant that has no known signature in any existing threat database?

○ A. Signature-based antivirus scanning comparing files against a database of known malware hashes

● B. AI-powered anomaly detection monitoring for unusual system behaviors such as unexpected process creation or abnormal outbound connections

○ C. Static perimeter blacklist filtering blocking traffic from a list of known malicious IP addresses

○ D. Scheduled weekly scans using the most recently updated malware definition database

Correct answer: B

Why: Zero-day malware has no known signature, so any detection method that depends on a database of known-bad indicators (A, B, D) cannot identify it. AI anomaly detection identifies unusual behavioral patterns, unexpected processes, abnormal network connections, that emerge from malware execution regardless of whether a signature exists.

*Why the others are wrong: **A**, Signature-based antivirus explicitly requires a known signature to match against; a zero-day by definition has no existing signature in any database. **C**, IP blacklists are reactive, they only block known-bad addresses that have already been identified and added to the list; zero-day infrastructure is unknown by definition. **D**, Scheduled definition updates help with known malware, but a zero-day has no definition to update to; weekly scanning also introduces a detection gap between update cycles.*

13. An AI SIEM analyzes login logs and detects the following for a single administrator account: successful logins from the same US-based IP address between 9 AM and 5 PM on weekdays for six months, followed by a successful login from a foreign IP address at 3 AM local time. The SIEM flags this as anomalous. Which principle BEST explains why this access pattern is suspicious?

○ A. The foreign login used an incorrect password multiple times, which is consistent with a brute-force credential attack

○ B. Logins originating from foreign IP addresses are universally blocked by standard network security policy

● C. The significant deviation from an established behavioral baseline suggests the account credentials may have been compromised

○ D. Administrator accounts should never be accessed during off-hours under any operational circumstances

Correct answer: C

Why: AI SIEMs flag deviations from established behavioral baselines. A sudden combination of geographic deviation (foreign IP) and time deviation (3 AM) from six months of consistent patterns is a strong anomaly signal consistent with credential compromise and unauthorized access. A is incorrect, the login succeeded, ruling out brute-force. C and D are overgeneralizations not consistent with real-world security policy.

*Why the others are wrong: **A**, The scenario states the login was successful; a successful login does not describe a brute-force attack, which involves repeated failed attempts before a possible successful one. **B**, Many organizations have globally distributed staff who legitimately log in from foreign IPs; a blanket foreign-IP block is not a universal standard and would be operationally impractical for many organizations. **D**, Administrators frequently perform legitimate maintenance during off-hours; the suspicious element is the combination of an unfamiliar geographic location and an unusual time simultaneously, not the hour alone.*

14. After the AI code-review tool flags injection vulnerabilities in the scenario's web application, the development team wants to verify that their fixes actually work before deploying to production. Which monitoring approach would generate the MOST useful evidence of whether the remediation was successful?

● **A. Run automated penetration tests in the test environment that simulate injection attacks and observe whether they succeed or fail**

○ B. Review the server's physical access logs to confirm only authorized developers made changes to the codebase

○ C. Review the company's password policy to confirm all developer accounts require strong credentials

○ D. Monitor the office building's CCTV footage during the testing period to confirm no unauthorized personnel were present

Correct answer: A

Why: Automated penetration testing directly generates application-layer evidence that the fix works by attempting the exact attack that was flagged and confirming whether it now fails. Physical access logs (B), password policies (C), and CCTV footage (D) address physical and authentication security layers that are entirely unrelated to whether an injection vulnerability in source code was successfully remediated.

*Why the others are wrong: **B**, Physical access logs document who entered the server room; they confirm personnel authorization, not whether the code change successfully prevents injection attacks. **C**, Password policy controls authentication strength; it provides no evidence about the application's resistance to database injection attacks after code remediation. **D**, CCTV footage monitors physical presence in a location; it generates no evidence about the behavior of application code under simulated attack conditions.*

15. An AI monitoring system flags an endpoint that is sending small, regular outbound packets to an unrecognized external IP address every 15 minutes, a pattern consistent with command-and-control (C2) beaconing. The endpoint's user reports noticing nothing unusual. Which action BEST represents sound evidence collection for the incident response team?

○ A. Reset the endpoint user's account password and close the incident ticket as resolved

● **B. Capture full network packets from the endpoint and cross-reference the external IP address against threat intelligence feeds**

○ C. Ask the user to restart their machine and monitor whether the outbound packets stop after the reboot

○ D. Disable the AI monitoring system until a human analyst can manually review the alert queue

Correct answer: B

Why: Full packet capture provides detailed evidence of communication content, timing, and destination. Cross-referencing the external IP with threat intelligence feeds can confirm whether it is a known C2 server, essential for incident scoping. A skips evidence collection entirely and doesn't address persistent malware. C and D both risk destroying or interrupting the only live evidence source available.

*Why the others are wrong: **A**, Resetting a password addresses credential-based attacks; C2 beaconing suggests malware persistence that survives a credential change, this action does not remediate the likely cause. **C**, A reboot may temporarily disrupt a malware process but destroys live forensic artifacts in memory and prevents capture of the active C2 communication for analysis. **D**, Disabling the monitoring system removes the active evidence source and the organization's primary detection capability at the exact moment a potential incident is unfolding.*

16. An AI monitoring tool generates 2,400 security alerts in a single 24-hour period. A security analyst samples the alerts and finds that 85% are false positives, legitimate activity incorrectly flagged, while the remaining 15% include three genuine high-severity incidents buried among hundreds of low-severity true positives. Which operational change MOST directly and appropriately addresses the root cause of this problem?

○ A. Disable the AI monitoring tool entirely and return to manual log review by the security team

● **B. Retrain or tune the AI model using labeled examples of true positives and false positives to improve detection precision**

○ C. Raise the alert severity threshold so the system only generates alerts for events it classifies as critical severity

○ D. Hire additional analysts to manually triage all 2,400 daily alerts generated by the existing system

Correct answer: B

Why: An 85% false-positive rate is a model precision problem, the model has not learned to distinguish enough between legitimate and malicious events. Retraining on labeled examples is the appropriate technical remedy that addresses the root cause. Disabling the tool (A) sacrifices true-positive detections with the false positives. Raising the threshold (C) risks suppressing genuine detections if they score below the new threshold. Scaling human labor (D) treats the symptom at unsustainable operational cost without fixing the model.

*Why the others are wrong: **A**, Disabling the AI tool eliminates all of its detections, including the genuine high-severity incidents it is finding, in exchange for eliminating false positives; net detection capability is reduced, not improved. **C**, Raising the alert threshold is a blunt instrument; genuine high-severity incidents may initially score below the new threshold if the model underestimates their severity, causing them to be silently dropped rather than triaged. **D**, Adding analysts scales human labor to match a broken model's output; it does not fix the model and creates an unsustainable operational burden that grows with alert volume rather than declining.*

17. An incident response team receives the following four AI-generated security alerts simultaneously. Evaluate which alert should be prioritized FIRST for investigation and response.

○ A. An AI phishing filter quarantined 12 incoming emails from a known bulk-mail domain before any user opened them

○ B. An AI vulnerability scanner identified a medium-severity CVE in a third-party library used by the internal development server

● C. An AI IDS detected an internal production server transmitting 40 GB of data to an unrecognized external IP address between 2:00 AM and 3:00 AM

○ D. An AI SIEM flagged a single failed login attempt on an employee's account originating from the employee's registered home IP address

Correct answer: C

Why: Large-scale outbound data transfer to an unknown external IP during off-hours is the highest-severity indicator, consistent with active data exfiltration in progress, which requires immediate containment. Alert A (quarantined phishing) is already contained. Alert C (medium CVE on a non-production server) requires patching but is not an active incident. Alert D (one failed login from a known IP) is within the range of normal operational noise and low severity.

*Why the others are wrong: **A**, The phishing emails have been quarantined, the threat has been neutralized by the control before any user interaction occurred; there is no ongoing active incident requiring immediate response. **B**, A medium-severity CVE on a non-production development server requires remediation planning, but it is not an active incident; the vulnerability is present but not being exploited in this alert. **D**, A single failed login attempt from a registered employee home IP is within normal operational noise, users occasionally mistype passwords; this alone does not constitute a credible active attack indicator.*

18. The scenario describes a human development team reviewing AI-generated code recommendations before pushing changes to production. Evaluate which statement BEST identifies the primary security benefit of this human-in-the-loop step AND correctly identifies the condition that would most directly undermine it.

○ A. Benefit: Human developers review code faster than AI tools can generate recommendations; undermined by: developers and the AI tool using incompatible integrated development environments

● B. Benefit: Human developers can evaluate business logic, deployment context, and edge cases the AI tool may not understand; undermined by: automatically accepting all AI recommendations without independent code review

○ C. Benefit: Human review guarantees that no security vulnerability will reach the production environment; undermined by: the organization deploying more than one AI code-review tool simultaneously

○ D. Benefit: Human review allows the AI tool to incorporate corrections into its model and improve its future recommendations; undermined by: development team members working across multiple time zones

Correct answer: B

Why: The primary benefit of human review is contextual judgment, developers understand business requirements, deployment architecture, and edge cases that the AI tool may mishandle or oversimplify. This benefit is directly and completely undermined if the team auto-accepts all recommendations without review, making the human-in-the-loop step

meaningless. B reverses the speed relationship between AI and humans. C overstates the guarantee, no review process eliminates all vulnerabilities. D conflates the human review step with an entirely separate model retraining workflow.

*Why the others are wrong: **A**, Human code review is generally slower, not faster, than AI-assisted analysis at scale; this factual reversal also identifies a compatibility concern (IDE mismatch) that is an operational friction issue, not a security undermining condition. **C**, Human review substantially reduces the probability of vulnerabilities reaching production but does not provide an absolute guarantee; the claim of total prevention is an overclaim that misrepresents what the review step achieves. **D**, Incorporating human corrections into future AI model training is a separate machine learning pipeline concern; time zone differences affect coordination but do not undermine the security benefit of reviewing a specific set of AI-generated recommendations.*